

Tài liệu dành cho người phụ trách kỹ thuật phía khách hàng: hệ thống được xây bằng gì, chạy ở đâu, bảo vệ dữ liệu ra sao, cần hạ tầng gì. Không đi vào chi tiết mã nguồn; tài liệu API đầy đủ có sẵn trên hệ thống (OpenAPI / Swagger).

1. Kiến trúc



Tách lớp rõ: **handler** → **service** → **repository**. Nghiệp vụ nằm trong service, không nằm ở giao diện — nên mọi kiểm tra (phân quyền, chuyển trạng thái, chính sách hủy) áp dụng cả khi gọi qua API.

2. Công nghệ

Thành phần	Công nghệ	Vì sao
Backend / API	Go 1.24+, Gin, GORM	Hiệu năng cao, một file thực thi, ít phụ thuộc, dễ vận hành trên VPS nhỏ
Cơ sở dữ liệu	PostgreSQL 13+	Mã nguồn mở, ổn định, sao lưu / phục hồi chuẩn, không phí license
Giao diện	Nuxt 3 (Vue 3), PWA	Một mã nguồn cho PC và điện thoại; cài lên màn hình chính, quét QR bằng camera
Xác thực	JWT có hạn, mật khẩu băm bcrypt	Chuẩn phổ biến, không lưu mật khẩu dạng đọc được
Excel	excelize (.xlsx)	Import / xuất đúng định dạng Excel, không lỗi font, không phụ thuộc Office
Đóng gói & triển khai	Docker, CI/CD (GitHub Actions), deploy không gián đoạn	Cập nhật phiên bản mà không dừng xưởng; kiểm tra /health trước khi chuyển lưu lượng
Tài liệu API	OpenAPI 3 + Swagger UI tại /docs	Tích hợp bên thứ ba không cần hỏi chúng tôi từng endpoint

3. Bảo mật

Kiểm soát	Cách thực hiện
Xác thực	JWT bắt buộc cho mọi API nghiệp vụ; thời hạn cấu hình được; mật khẩu băm bcrypt, không lưu dạng thô.
Phân quyền	10 vai trò, kiểm tra ở tầng API cho từng nhóm route và kiểm tra lại trong service với thao tác nhạy cảm (sửa / huỷ / xoá đơn). Seller chỉ truy cập được dữ liệu của chính mình — ép ở service, không dựa vào giao diện.
Chống dò mật khẩu	Giới hạn 10 lần đăng nhập / phút / IP; chỉ tin proxy được khai báo để không bị giả mạo IP.
Đầu vào	Giới hạn kích thước body; kiểm tra dữ liệu theo trường với thông báo tiếng Việt; chuẩn hoá mã; tải URL ngoài qua bộ lọc chống SSRF.
CORS	Danh sách origin cho phép, cấu hình theo môi trường.
Cấu hình production	Chặn khởi động nếu thiếu JWT secret, mật khẩu demo mặc định, hoặc cấu hình hờ; tài khoản demo tự thu hồi khi tắt cờ seed.
Nhật ký	Audit log mọi thao tác nghiệp vụ (ai, gì, lúc nào, trên bản ghi nào); request-id cho từng yêu cầu; lỗi 5xx ghi nguyên nhân gốc phía server, không lộ ra client.
Dữ liệu	Xoá mềm; job dọn rác định kỳ theo thời hạn lưu; thông tin đối tác vận chuyển được che theo vai trò.
Truyền tải	HTTPS/TLS qua reverse proxy (Caddy / Nginx); secret qua biến môi trường, không nằm trong mã nguồn.

4. Vận hành & độ tin cậy

- **Health check** `GET /health` (hỗ trợ cả HEAD) cho giám sát và load balancer.
- **Deploy không gián đoạn**: bản mới khởi động, qua kiểm tra health rồi mới nhận lưu lượng; bản cũ tắt sau.
- **Tác vụ nền**: đồng bộ tracking theo lịch; dọn dữ liệu xoá mềm quá hạn.
- **Hiệu năng**: truy vấn tối ưu cho danh sách lớn, chống xung đột ghi đồng thời (race), tuning pool kết nối và index. Đã tối ưu tốc độ xác nhận import.
- **Sao lưu (khuyến nghị)**: `pg_dump` hàng ngày, giữ 30 ngày, bản sao ngoài máy chủ; diễn tập phục hồi mỗi quý.
- **Giám sát (khuyến nghị)**: uptime monitor vào `/health`, cảnh báo dung lượng đĩa và DB.

5. Tùy chọn triển khai

Phương án	Ưu điểm	Lưu ý
Cloud do chúng tôi vận hành (VPS tại Việt Nam)	Nhanh nhất; chúng tôi lo sao lưu, giám sát, cập nhật; phí vận hành gộp	Mỗi khách một instance riêng (không dùng chung DB). Dữ liệu thuộc khách, xuất bất cứ lúc nào.
VPS / cloud của khách	Khách kiểm soát hạ tầng và hoá đơn cloud	Cần cấp quyền truy cập để triển khai và hỗ trợ; khách chịu trách nhiệm sao lưu nếu không mua gói vận hành

Phương án	Ưu điểm	Lưu ý
On-premise (máy chủ tại xưởng)	Dữ liệu không rời xưởng; chạy được khi mất Internet nội bộ (nếu có mạng LAN)	Cần UPS, sao lưu ngoài, người quản trị; tracking / seller từ xa cần mở Internet; phí triển khai cao hơn

6. Yêu cầu hạ tầng

Máy chủ (cho xưởng ≤ 2.000 đơn/ngày) 2 vCPU, 4 GB RAM, 40 GB SSD (khuyến nghị 4 vCPU / 8 GB khi > 50 người dùng đồng thời) - Ubuntu 22.04+ hoặc tương đương, Docker - PostgreSQL 13+ (cùng máy hoặc managed) - Tên miền + chứng chỉ TLS; mở cổng 443	Phía người dùng - Trình duyệt hiện đại (Chrome, Edge, Safari) - Điện thoại iOS / Android có camera cho trạm QC, đóng gói, bàn giao - Máy in tem QR (nhiệt, khổ [] mm) - Internet ổn định tại xưởng; 4G dự phòng
--	---

7. Dữ liệu & quyền sở hữu

- Toàn bộ dữ liệu nghiệp vụ (đơn, seller, danh mục, nhật ký) **thuộc về khách hàng**.
- Xuất dữ liệu: Excel/CSV từ giao diện; bản sao DB (dump) theo yêu cầu; qua API.
- Khi kết thúc hợp đồng: bàn giao bản dump, xoá khỏi hạ tầng của chúng tôi trong 30 ngày, có xác nhận.
- Truy cập của chúng tôi vào production chỉ để hỗ trợ, có nhật ký, theo thoả thuận bảo mật.

8. Tích hợp & mở rộng

- REST API** có tài liệu OpenAPI; envelope JSON thống nhất; mã lỗi rõ ràng.
- Hãng vận chuyển**: interface adapter — thêm hãng mới không sửa nghiệp vụ.
- Tracking**: nhà cung cấp thay được; tắt được bằng cấu hình.
- Chưa có sẵn** (tuỳ biến): webhook đẩy sự kiện, SSO / đăng nhập Google, xác thực 2 lớp, kết nối sàn TMĐT.

9. Hạn chế hiện tại — nói thẳng

Hạn chế	Ý nghĩa với khách & hướng xử lý
Mỗi bản cài phục vụ một công ty / một xưởng	Nhiều xưởng của cùng chủ → nhiều instance hoặc tuỳ biến đa xưởng (mức cao). Không ảnh hưởng xưởng đơn lẻ.
Migration schema tự động (AutoMigrate)	Phù hợp giai đoạn hiện tại; sẽ chuyển sang công cụ migration có phiên bản khi cần quản lý chặt hơn — không đổi dữ liệu.
Chưa tạo vận đơn trực tiếp với hãng	Hiện gán mã vận đơn nhận từ hãng (lẻ / hàng loạt). Tạo vận đơn trực tiếp = 1 adapter / hãng.
Chưa có SSO / 2FA	Đăng nhập email + mật khẩu, JWT có hạn, giới hạn tần suất. Bổ sung theo yêu cầu.